DOC NS-OSINT-IT01
REV 1.0



NIGHTSCRY

[SEE EVERYTHING. EXPLOIT WEAKNESS.]

ITALIAN CYBERSECURITY™

AN OSINT RESEARCH BY **NIGHTSCRY**

ITALIAN CYBERSECURITY IS SOMETHING ELSE. 🇮🇹💀

ONE CHARACTER. ONE SQL ERROR. 36 EXPOSED INSTALLATIONS.

01 — ORIGIN

1. “We weren’t hired.”

We weren't hired. We were just doing OSINT.

We found a web application and decided to take a closer look.

Nothing fancy. No exploit chain. No brute force. No 0-day.

We sent one character in the username field:

```
POST /login HTTP/1.1
Content-Type: application/x-www-form-urlencoded

username='&password=test
```

That was it. That was the whole attack — the kind of input every login form on earth is supposed to survive without blinking.

> OBSERVATION
> This one didn't survive it. The server replied with a raw, unhandled exception instead of a login failure. In most countries this qualifies as a finding. In Italian enterprise software, it qualifies as a Tuesday.

Somewhere, a developer typed `"SELECT ... WHERE USERNAME='" & input & "'"` in 2011, shipped it, and never thought about it again. Neither did anyone else, apparently.

02 — THE RESPONSE

2. The application answered for us.

No WAF. No generic “something went wrong.” Just a raw, unhandled `SqlException`, the exact query string, and a full stack trace — served straight to the browser.

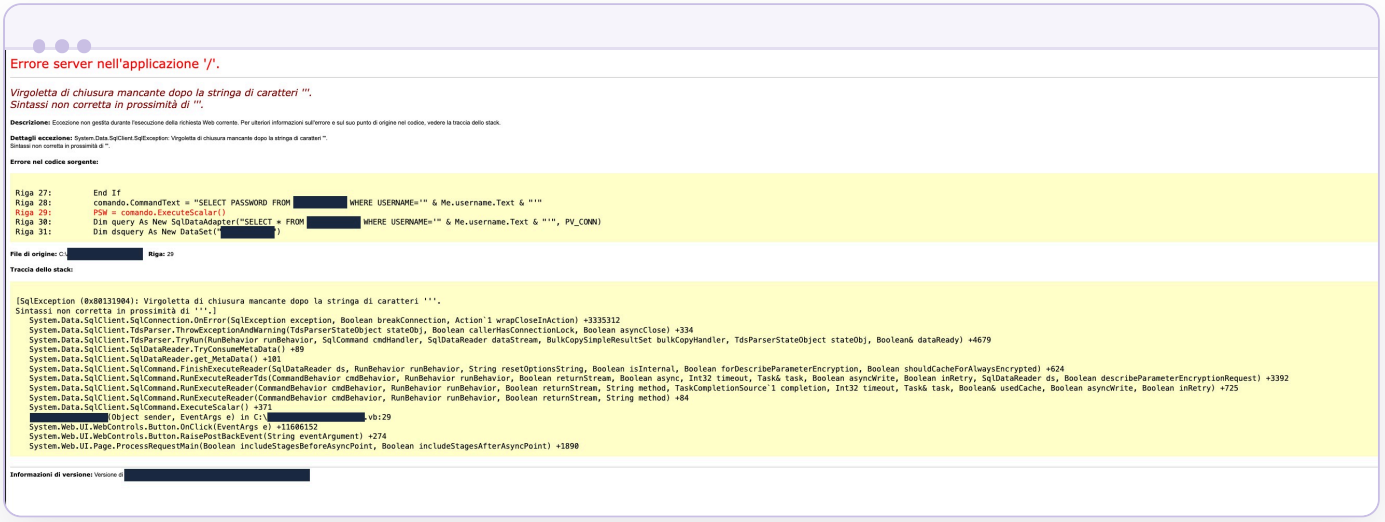


FIG. 1 — Unhandled SQL exception returned by the login endpoint after a single quote (') was submitted in the username field. Identifying paths and table names redacted by Nightscry.

> EDITORIAL NOTE
>
> The stack trace kindly includes the file path, the query, and the exact line number. Digital hospitality at its finest — nobody in this codebase has heard of `customErrors mode="On"`, and it shows.

03 — ONE IS NEVER ENOUGH

3. A bug like this is never really alone.

A stack trace this clean isn't usually a one-off mistake by one unlucky developer. It's a pattern — the kind that gets copy-pasted from one deployment to the next, along with the rest of the codebase.

So we stopped looking at **the application** and started looking at **the software behind it**: same login page, same HTML title, same missing sanitization — just fingerprinted at internet scale.

> PATTERN
> Same product. Same broken login. **Multiplied.** Presumably by the same intern, on the same deadline, with the same "we'll fix it later."

A few minutes with a search engine for exposed services was enough to turn one forgotten login page into a census. No 0-day required — just a vendor with a favorite mistake and a long client list.

METRIC	VALUE	STATUS
Characters sent	1	MINIMAL
Exploit chains used	0	NONE
Installations found running the same bug	36	EXPOSED
Input sanitization detected	0	ASPIRATIONAL
Estimated years since anyone reviewed this code	10+	VINTAGE

> ITALIAN DIGITAL TRANSFORMATION™
> No exploit. No payload. No fancy shit. Just `'` → `SQL ERROR`.
> Millions spent on "innovation." One apostrophe later: 💀

04 — SCALE

4. Censys agreed.

One targeted fingerprint query, indexed results, done. Thirty-six live web properties running the exact same vulnerable login page — under a second of search time.

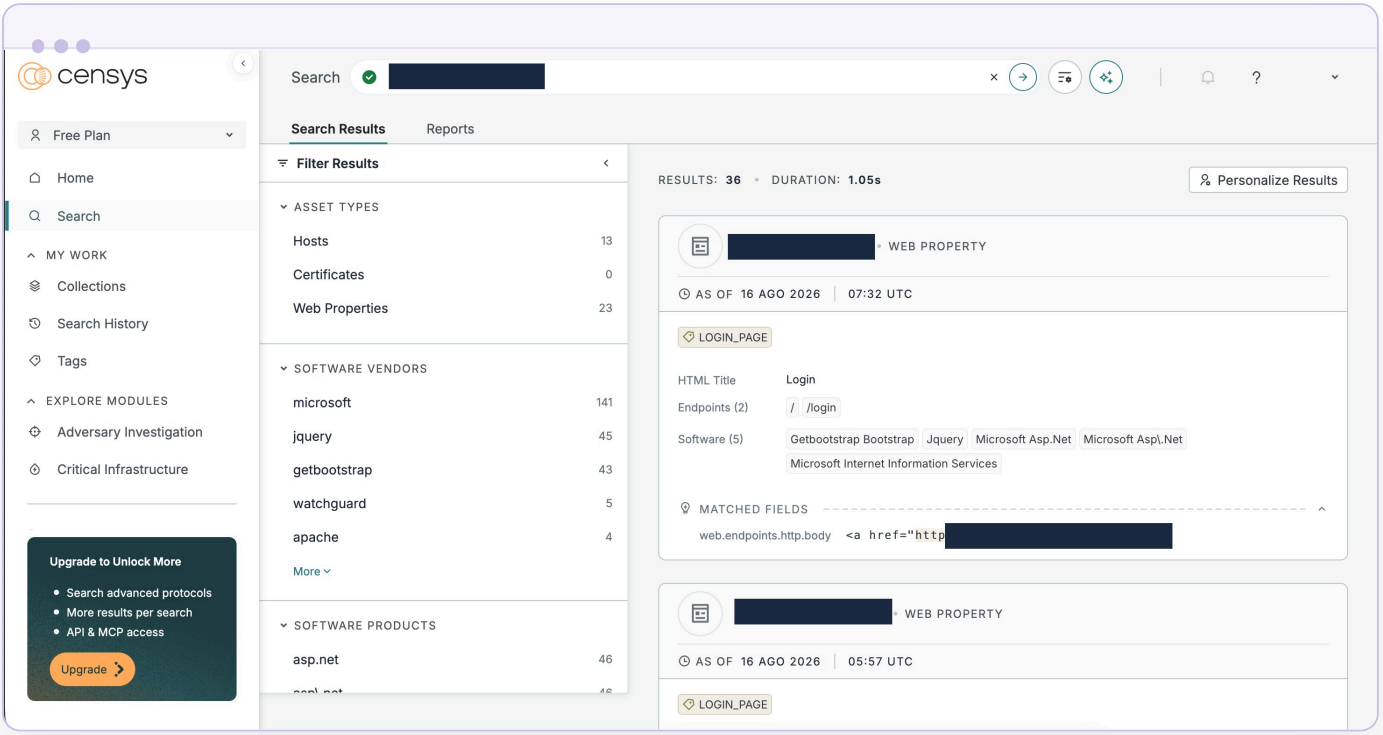


FIG. 2 — 36 matching web properties running the same login page fingerprint, indexed by Censys. Hostnames and endpoints redacted by Nightscry.

05 — CLOSING NOTES

5. This is not a hack.

It's what happens when a single unescaped quote is the only thing standing between a login form and someone else's incident report.

SECURITY ASSESSMENT, ITALIAN EDITION

- "Does the website open?" ✅ Yes.
- "Can customers log in?" ✅ Yes.
- "Can the database scream its SQL errors at strangers?" 🇮🇹 Ma sì, tanto chi vuoi che se ne accorga.

DISCLOSURE

- No data was extracted.
- No accounts were accessed.
- No further testing was performed beyond confirming the error was reproducible.
- All targets, endpoints and identifiers in this document have been redacted.

This report documents a pattern, not a target. Responsible disclosure is in progress with the relevant parties.

Consider this a professional courtesy. The next researcher poking at the same login page might not write you a report — they might just write themselves an account.

NIGHTSCRY

SEE EVERYTHING. EXPLOIT WEAKNESS.

MADE WITH PUBLIC DATA, MILD SARCASM, AND PROFOUND DISAPPOINTMENT.